

Towards a Software Supply Chain Security Barometer: A Model to Assess and Guide Community Efforts

Sivana Hamer. Advisors: Laurie Williams and William Enck
North Carolina State University

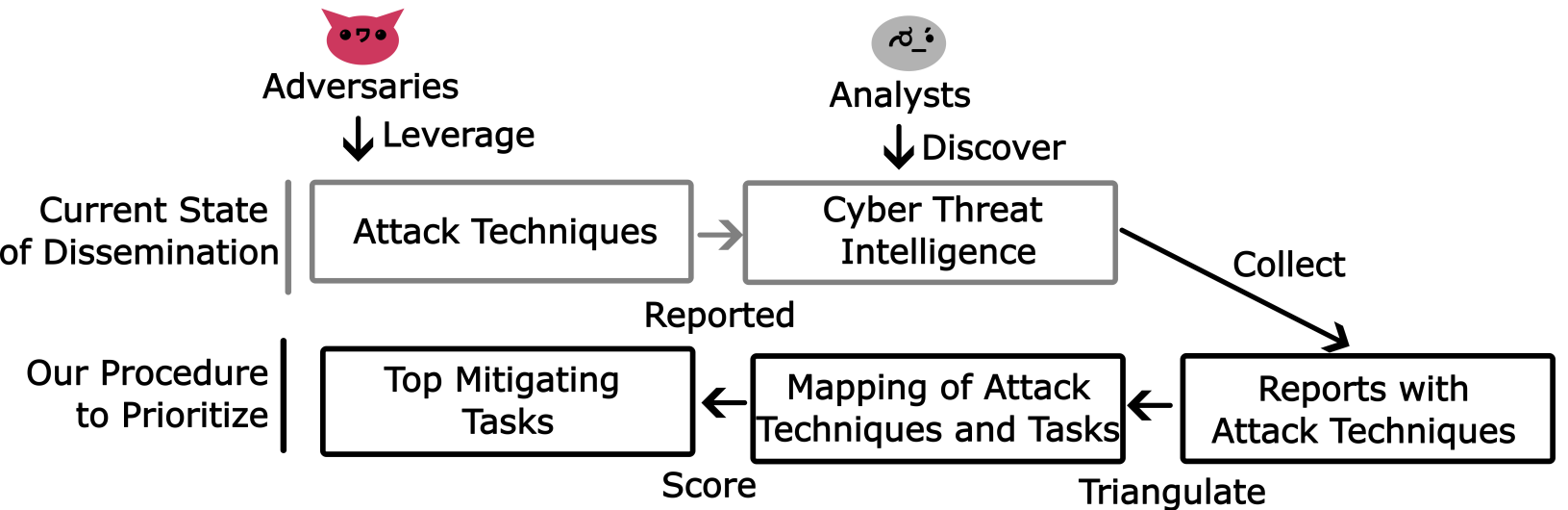
Introduction

Despite worldwide efforts across communities invested in software supply chain security, vulnerabilities continue to rise. Although more resources can be invested, sustainable long-term solutions are needed. Our goal is thus to **assess and guide organizations, ecosystems, and researchers by developing a barometer model of software supply chain security**. Our model determines tasks that:

1. Mitigate attack techniques
2. Are attested to
3. Improve security outcomes.

Study 1: Attack Techniques (published)

The goal of this study is to aid software organizations in reducing the risk of software supply chain attacks by systematically synthesizing how framework tasks mitigate the attack techniques used in the SolarWinds, Log4j, and XZ Utils attacks.

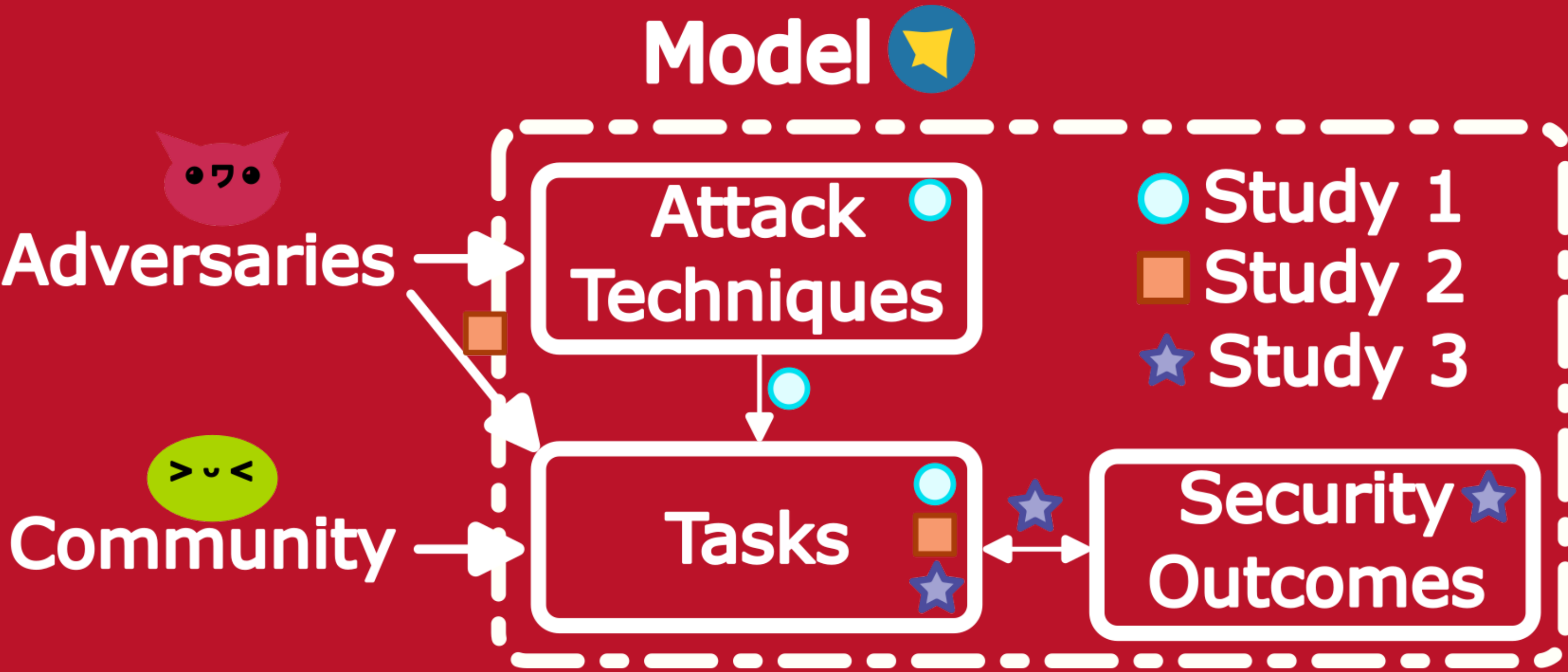


Challenges: Challenging attack technique collection and a lack of mapping attack techniques to tasks.
Insights: Understanding what attack techniques are used in attacks (e.g., XZ Utils) and how they map to tasks (e.g., SLSA).

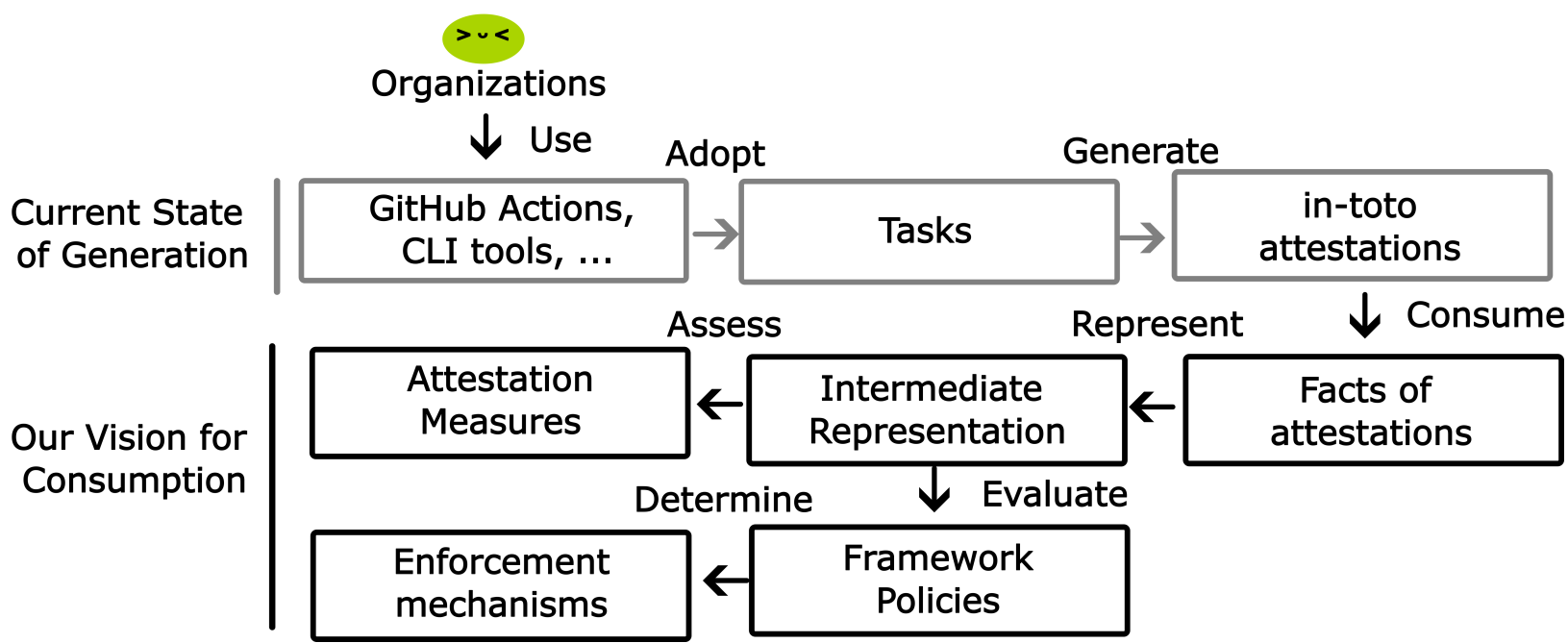
Study 2: Attestation Measures (ongoing)

The goal of this research project is to aid software organizations in providing evidence-based automated assessments by consuming available in-toto attestations into empirical statements about the state of the software supply chain: (1) measuring the state of generation and (2) enforcement policies through consumption.

What tasks help software organizations reduce software supply chain security risk?



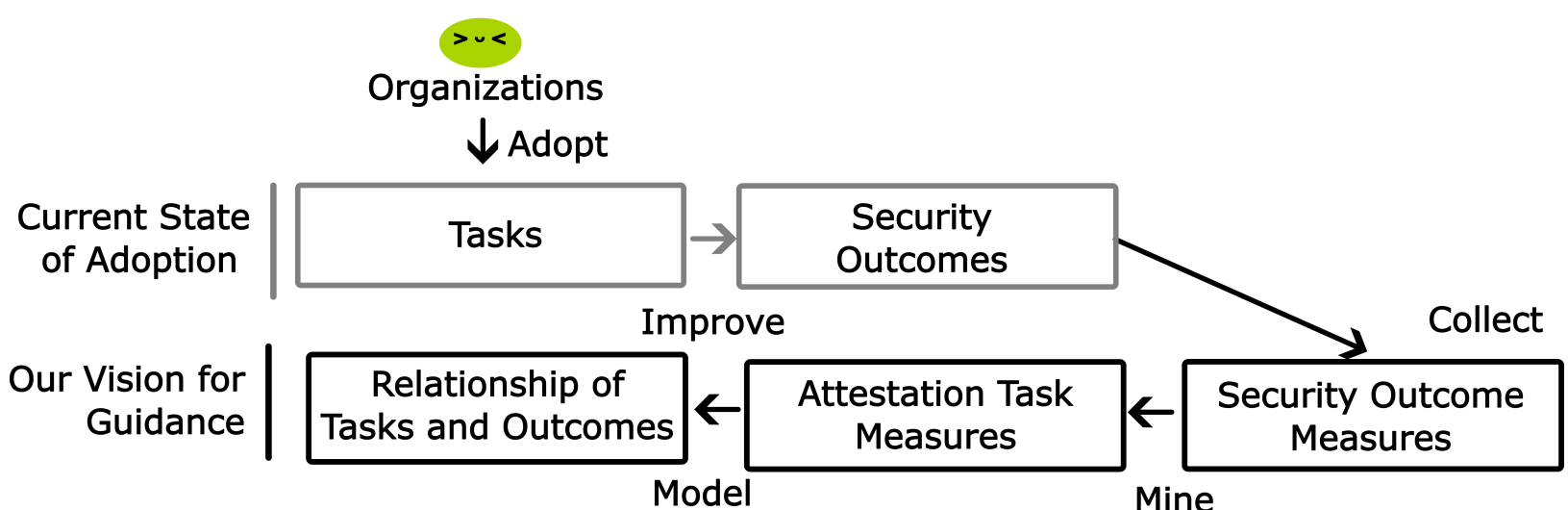
Contact: Sivana Hamer | sahamer@ncsu.edu



Challenges: Data is hard to get, unnormalized, not mapped to frameworks, and unstandardized policies.
Insights: Measure existing tasks adopted and enforcement mechanisms for frameworks.

Study 3: Security Outcomes (proposed)

The goal of this research project is to aid the software supply chain community to assess the state of software supply chain security by developing a barometer model that quantitatively analyzes the relationship between task adoption and security outcomes.



Challenges: Defining security outcomes, missing attestation data, and longitudinal analysis.
Insights: Connecting attacks, attack techniques, and tasks into a model.

Broader Impact of the Research

- Collaboration with Google Open Source Software Security Team, in-toto CNCF project, and producers of in-toto.
- Presented at US DoD, MITRE, and US Air Force.
- Press releases (e.g., The Register).
- Sent improvements to frameworks, including MITRE ATT&CK and NIST SSDF.

Acknowledgements

The work was supported and funded by the NSF Grant No. 2207008, NCSU Goodnight Doctoral Fellowship, and Google PhD Fellowship. Any opinions expressed in this material are those of the authors and do not necessarily reflect the views of any of the funding organizations.